

Cloudora incident report

Ticket: CLD-0001 | Priority: P1 (training assignment) | Classification: simulated client engagement

Status: guide-based assessment; independent log validation pending. Prepared 2026-10-07. Event date: 2026-08-10. Times below follow the guide's UTC convention.

Executive summary

The training guide describes suspicious successful access to CEO Daniel Reeve's account after failed sign-ins from Lagos. It also describes a newly registered authenticator and an inbox rule hiding finance-related messages, consistent with persistence and business-email-compromise staging. The guide links the activity to a multi-account password spray and indicates a second affected user whose identity is not supplied in the PDF. No source logs were provided for independent confirmation, and containment actions in this report are recommendations rather than completed work.

Evidence and limitations

Only the four-page student guide was supplied. The two referenced CSVs, query pack, blank report template, completed example, and answer key were not supplied. No queries have been executed against the source dataset, no genuine result screenshots are available, and no tenant actions were performed.

Geo-location is an investigative lead. Credential acquisition and initial MFA handling remain unproven. Mailbox access does not establish message exfiltration or executed fraud. Absence of success in limited logs cannot prove an account is safe.

Timeline from the guide

- 03:09 and 03:10: CEO failures from 102.89.44.17, Lagos (p. 2).
- 03:12: successful CEO sign-in (p. 2).
- 03:14: Outlook Web access (p. 2).
- 03:18: authenticator registration labelled Pixel 6 (p. 2).
- 03:26: Azure Portal access (p. 2).
- 03:31: RSS Subscriptions inbox rule hides finance/invoice messages (pp. 2-3).
- 08:41: CEO London sign-in (p. 2).
- 08:55: IT administrator reports the anomaly (p. 1).

Precursor: guide describes three nights of failures across 25+ accounts, typically one to three attempts per account. Exact counts and dates require query 03.

Findings and scope

F1 - Suspected executive account takeover: the guide-described failure-success sequence, applications, and audit changes jointly support compromise more strongly than geo-location alone. Validate using queries 01, 02, and 04.

F2 - Password-spray pattern: known addresses are 102.89.44.17, 102.89.44.23, and 102.89.45.101. Activity is consistent with T1110.003, followed by T1078 credential use. Direct causal linkage is a hypothesis pending log analysis.

F3 - Persistence: authenticator registration maps to T1098.005 in the guide. Verify successful registration, target, and actor. An attacker-controlled method may maintain access depending on authentication policy; password reset alone is insufficient cleanup.

F4 - Email hiding: the rule maps to T1564.008 and supports BEC staging. Verify exact rule conditions and actions. Financial loss, forwarding, data exfiltration, and invoice alteration are not established.

F5 - Wider scope: CEO is named; a second victim is mentioned but unnamed. Query 05 must identify candidates, followed by query 08. Targeted users without observed known-IP successes remain pending query 07. Do not report a final affected-account count.

F6 - Travel comparison: Omar Farah's Dubai activity is described as daytime, successful on the first attempt, using his usual iOS device across three days. This is consistent with travel, but independent verification of device continuity and travel is pending (p. 2).

Business impact assessment

Potential executive impersonation, finance-message suppression, mailbox confidentiality loss, and interference with an upcoming enterprise deal. These are exposure scenarios rather than proven consequences. Assess actual mailbox reads, sends, forwarding, OAuth grants, privileged operations, and downstream financial communications using additional telemetry where available.

Actions taken

Prepared a commented KQL investigation pack, evidence register, detection prototype, and this report. No account disabling, session revocation, credential reset, MFA removal, rule deletion, or blocking occurred.

Recommended response

1. Preserve sign-in/audit evidence and rule/authentication-method configuration; coordinate with the authorized incident owner.
2. Restrict affected-account access and revoke sessions; review token/session limitations and application access.
3. Reset credentials, remove unauthorized methods, and securely re-register authentication factors.
4. Remove malicious inbox rules; review forwarding, delegates, consent grants, and sent/deleted messages.
5. Scope all successful suspect access and failed targets; the guide calls for resets for near-misses, subject to the real incident owner's response policy.
6. Consider narrowly scoped controls for confirmed infrastructure with appropriate administrator review; do not block a broad prefix on geography alone.
7. Validate account recovery and monitor broader activity, including changed methods/rules and new infrastructure. Coordinate finance verification if invoice manipulation is suspected.

Detection and closure

Query 06 proposes a rolling six-hour spray threshold. Historical replay, tuning, and Sentinel deployment are pending. Close only after affected accounts are established, artifacts removed, recovery verified, business impact assessed, and evidence reviewed by the incident owner. This case is not ready for an evidence-verified closure.

Source

MyFirstHack / myfirstcyberjob, Cloudora student guide, CLD-0001, pp. 1-4. This document is an original guide-based assessment, not the missing CLD-IR-TEMPLATE or answer key.